SECURITY INCIDENT REPORT

Payroll-themed credential phishing campaign

Two accounts compromised via a lookalike portal

Completed for portfolio purposes. Cloudora is a fictional company and all data is synthetic.

Report ID	CLD-IR-0002
Related ticket	CLD-0002: Reported phishing email impersonating Cloudora HR (payroll theme)
Analyst	Gold Adegbola, Cloudora engagement (training scenario)
Incident date (UTC)	2026-08-25
Date of report (UTC)	2026-09-30
Environment	Microsoft Entra ID, Azure Data Explorer (KQL), VS Code
Incident severity	P1: two staff accounts compromised and actively signed into by an external attacker; live credential theft against a company that holds customer payroll data
Status	Contained. Eradication verified, monitoring continues
Classification	CONFIDENTIAL: Internal and client distribution only

1. Executive summary

On 25 August 2026 an external attacker sent a payroll-themed phishing campaign to 40 Cloudora staff, impersonating Cloudora HR and asking recipients to confirm their payroll details before 5:00 p.m. on a lookalike website. The campaign used two message styles: one that forged the real cloudora.io address and failed every authentication check, and one sent from a convincing lookalike domain that passed authentication for that fake domain. Six employees clicked the link and two entered their passwords.

The attacker used both stolen passwords the same day, signing in to those two accounts from the same address in Amsterdam on an unfamiliar Windows and Chrome device. Pivoting on that address showed it had successfully signed in to no other Cloudora account.

The campaign was reported by a member of staff on the morning of 25 August. Both accounts were contained that afternoon, the attacker’s access was cut off, the sending and hosting infrastructure was blocked, and the phishing messages were purged from mailboxes. A marketing newsletter reported alongside the phish was confirmed legitimate. Four further staff who clicked but did not enter credentials are being treated as elevated risk.

2. Incident timeline

All times UTC. Sources: CloudoraMsgTrace_CL (Exchange Online message trace), CloudoraSignin_CL (Entra ID sign-in logs), and the reported .eml files.

Time (UTC)	Source	Event
Aug 25, 06:58	Msg trace	Legitimate Cloudora newsletter delivered via Mailchimp (later reported, cleared as a false positive)
Aug 25, 08:04-08:20	Msg trace	Phishing variant A, wave 1, sent from 198.18.44.10 spoofing payroll@cloudora.io; SPF/DKIM/DMARC fail; some copies quarantined by EOP, some delivered
Aug 25, 08:35-08:50	Msg trace	Variant A wave 2 from 198.18.44.23, and variant B from 198.18.51.7 using lookalike domain cloudora-hr-portal.example (auth passes for the fake domain)
Aug 25, 08:39:03	Msg trace	seth.lane clicks the variant A link; no credentials submitted
Aug 25, 08:47:12	Msg trace	freya.lynn clicks variant A and SUBMITS credentials
Aug 25, 09:05:44	Msg trace	ryan.boyd clicks variant B and SUBMITS credentials
Aug 25, 09:11	Ticket	james.holt forwards the phish to the SOC; ticket CLD-0002 raised, investigation starts
Aug 25, 09:58 / 10:12 / 11:47	Msg trace	hugo.marsh, chloe.price and dina.said click the link; none submit credentials
Aug 25, 10:34:20	Sign-in	Attacker signs in as freya.lynn from 198.18.7.200 (Amsterdam, NL) on Windows 11 / Chrome: harvested credential used (T1078); Outlook Web 10:36, SharePoint 10:41
Aug 25, 13:22:05	Sign-in	Attacker signs in as ryan.boyd from 198.18.7.200 (Amsterdam): second account used; Outlook Web 13:25
Aug 25, ~14:00	Response	Containment executed on both accounts (see section 7)

3. Findings

Finding 1: A payroll-themed phishing campaign was delivered to staff

On 25 August, 40 Cloudora mailboxes were targeted by a phishing campaign using the subject lines ‘Payroll update: action required before 5pm’ and ‘Action required: confirm your August payroll details’. Both impersonated Cloudora HR and linked to cloudora-hr-portal.example, a lookalike of cloudora.io. The messages pressured staff to confirm payroll details before 5:00 p.m., implying that salary could be held.

Evidence: the message trace delivery query (40 records) and the reported .eml files, reviewed as raw text without opening them in a mail client.

Finding 2: The campaign used two authentication tactics; passing authentication did not mean safe

Variant A forged the real address payroll@cloudora.io and failed SPF, DKIM and DMARC (compauth=fail), sent from 198.18.44.10 and 198.18.44.23. Its Reply-To pointed to hr-support@cloudora-hr-portal.example, while Cloudora’s genuine HR portal is myhr.cloudora.io.

Variant B was sent from the attacker’s own lookalike domain cloudora-hr-portal.example (198.18.51.7) and PASSED SPF, DKIM and DMARC, but for the lookalike domain, not for Cloudora. Authentication only proves the sending domain, not its legitimacy, so both variants are malicious.

Threat intelligence was used only after this evidence was established: VirusTotal and AbuseIPDB results were treated as supporting context, not standalone proof. This is the same test that clears the false positive in Finding 6.

Finding 3: Two accounts submitted credentials and were compromised

freya.lynn@cloudora.io and ryan.boyd@cloudora.io both clicked and submitted credentials (message trace click events at 08:47 and 09:05). Both were then signed into from 198.18.7.200 (Amsterdam, Netherlands) on a Windows 11 / Chrome device not seen in their normal activity.

- **Freya:** normal sign-in from Manchester on an iPhone at about 08:30, then an attacker sign-in from Amsterdam at 10:34. The short gap between two distant locations is an impossible travel indicator. The attacker accessed Microsoft 365, Outlook Web and SharePoint Online.
- **Ryan:** normal sign-in from London on an iPhone at about 08:13, then an attacker sign-in from the same Amsterdam IP, device and browser at 13:22. The gap is long enough that travel would be possible, so his account was assessed on the other indicators rather than impossible travel. The attacker accessed Microsoft 365 and Outlook Web.

Impossible travel alone is an indicator, not proof, because VPNs, proxies and inaccurate geolocation can produce the same pattern. Confidence that these sign-ins were unauthorized is high because each followed a credential submission, came from an unfamiliar device and browser, and shared one source IP. This is use of harvested valid credentials (T1078).

Finding 4: Four further staff clicked the link but did not submit credentials

seth.lane, chloe.price, hugo.marsh and dina.said clicked the phishing link with no credentials submitted. The attacker IP pivot (Finding 5) returned no successful sign-ins for these accounts, so they are not confirmed compromised. A click means they reached the harvesting page, so they are treated as elevated risk pending a precautionary password reset and a direct check-in.

Finding 5: The attacker IP pivot found two affected accounts and no others

Searching every successful sign-in from the 198.18.7.x range returned exactly two accounts, freya.lynn and ryan.boyd, both from 198.18.7.200. Pivoting from the first victim is what surfaced the second, and it limited the confirmed suspicious access to these two accounts.

Finding 6: The reported Mailchimp newsletter is legitimate (false positive, cleared)

The ‘Cloudora Monthly’ newsletter was sent for Cloudora via Mailchimp. It passes SPF, is DKIM-signed and aligned to cloudora.io, passes DMARC, carries a valid one-click List-Unsubscribe, and is signed a second time by the third-party mailing infrastructure (mcsv.net), which is expected for Mailchimp. Unlike variant B, its authentication aligns to the genuine cloudora.io brand.

Verdict: legitimate marketing mail, not part of the attack. Cleared with evidence so it is not re-investigated.

4. Indicators of compromise (IOCs)

Type	Value	Context
Domain	cloudora-hr-portal.example	Lookalike of cloudora.io; phishing / credential harvesting; subdomains mail., mailer., login.
URL	hxxps://cloudora-hr-portal[.]example/payroll/login	Variant A harvesting link (defanged)
URL	hxxps://login.cloudora-hr-portal[.]example/verify	Variant B harvesting link (defanged)
IPv4	198.18.44.10	Variant A wave-1 sending relay + harvest host (Amsterdam, synthetic)
IPv4	198.18.44.23	Variant A wave-2 sending relay (same /24)
IPv4	198.18.51.7	Variant B sending relay
IPv4	198.18.7.200	Attacker sign-in IP (Amsterdam): harvested credential use; blocked
Sender	payroll@cloudora.io (spoofed)	Forged From on variant A; Reply-To hr-support@cloudora-hr-portal.example
Sender	payroll@cloudora-hr-portal.example	Variant B From (lookalike domain)
Subject	Payroll update: action required before 5pm	Variant A
Subject	Action required: confirm your August payroll details	Variant B

5. MITRE ATT&CK mapping

Tactic	Technique ID	Technique name	Evidenced by
Initial Access	T1566.002	Phishing: Spearphishing Link	Findings 1-2, the two phishing variants and their links
Reconnaissance	T1598.003	Phishing for Information: Spearphishing Link	The credential-harvesting page behind the link
Initial Access	T1078.004	Valid Accounts: Cloud Accounts	Finding 3, attacker sign-ins with harvested credentials

Context technique (infrastructure): the attacker registered and hosted a lookalike domain (T1583.001, Acquire Infrastructure: Domains). Mapped for awareness; not directly evidenced in these logs beyond the domain itself.

6. Scope

Accounts confirmed compromised (2)

freya.lynn@cloudora.io (attacker sign-in 10:34:20 UTC) and ryan.boyd@cloudora.io (13:22:05 UTC), both 25 Aug, both from 198.18.7.200; both submitted credentials to the phishing page.

Accounts clicked but not confirmed compromised (4)

seth.lane, chloe.price, hugo.marsh, dina.said: clicked the link, no credentials submitted, no successful sign-in from the attacker IP range. Precautionary reset and direct check-in.

Accounts targeted with no recorded click (34)

The remaining 34 of the 40 targeted mailboxes show no click. They form the near-miss list for user communications and awareness follow-up.

Emails investigated and cleared (1)

The ‘Cloudora Monthly’ Mailchimp newsletter: legitimate marketing mail (Finding 6).

7. Actions taken

Executed afternoon of 25 Aug (UTC), in order. In this training scenario these are the documented response decisions; in a live tenant each row would carry the operator and change ticket.

Order	Action	Why this order matters
1	Revoked all active sessions and refresh tokens for freya.lynn and ryan.boyd	Kills the attacker’s live sessions immediately; a reset alone leaves an open session working
2	Reset credentials for both compromised accounts	New passwords only matter once the stolen sessions are dead
3	Required and re-registered MFA on both accounts	Both fell to a password alone; MFA stops a harvested password being enough next time
4	Blocked infrastructure: 198.18.44.10, 198.18.44.23, 198.18.51.7, 198.18.7.200 and cloudora-hr-portal.example (all subdomains) at mail gateway and web proxy	Cuts off sending, hosting and the login IP
5	Purged delivered phishing messages from all mailboxes (soft delete / ZAP)	Stops anyone else clicking a copy that is still sitting in an inbox
6	Verified: re-ran the victim sign-in and attacker-IP pivot queries; no 198.18.7.200 activity after containment	Containment is a claim until you prove it in the logs

8. Recommendations

- Precautionary password resets and a direct check-in for the four clicked-but-no-credential staff; user communications and awareness for the thirty near-miss recipients.
- Enforce MFA on all accounts and disable legacy authentication that bypasses it; both compromises were password-only.
- Move cloudora.io DMARC policy to p=reject so spoofing variants like variant A are rejected outright, not merely quarantined, and downstream recipients reject them too.
- Add mail-gateway detection for newly-registered lookalike domains and for external mail whose From is cloudora.io but which fails DMARC.
- Deploy a sign-in detection for a successful sign-in from a new country within a few hours of a phishing-link click. This would have flagged both compromises the same morning.
- Block the phishing infrastructure permanently and monitor for the actor re-registering adjacent lookalike domains.

9. Lessons learned

Passing SPF, DKIM and DMARC does not make an email legitimate: variant B and the Mailchimp newsletter both pass, and only checking which domain they pass for, and whether that domain belongs to the organization, tells them apart.

Lookalike domains remain effective, so staff should be trained to read the full domain rather than the display name. Anyone who submits credentials needs immediate identity investigation, and email evidence alone would not have shown the impact: it took the chain of email, message trace, credential submission and Entra ID sign-ins to reach the real scope.

Pivoting on the attacker sign-in IP is what confirmed the second victim and bounded the incident, so never stop at victim one.

10. Limitations and references

This report covers delivery, user interaction, credential exposure and sign-in activity. What the attacker did inside the two mailboxes and SharePoint Online after signing in (for example mail read or forwarded, files accessed) was not assessed and should be reviewed as a follow-up.

The domain and IPs in this scenario are synthetic, so the VirusTotal and AbuseIPDB screenshot used in the investigation are simulated, so their figures are supporting context only.

The full step-by-step investigation, queries and evidence screenshots are in the accompanying investigation documentation (CLD-0002).

End of report CLD-IR-0002. Cloudora is a fictional company; all data is synthetic.